

Aula 16 - Vulnerabilidade de Software

Prof. Gabriel Rodrigues Caldas de Aquino

Instituto de Computação
Universidade Federal do Rio de Janeiro
gabrielaquino@ic.ufrj.br

Compilado em:
November 18, 2025

- **A Raiz do Problema:**

- Muitas vulnerabilidades de segurança resultam de **práticas de programação ruins**.
- A conscientização sobre essas falhas é um passo inicial crítico para escrever código de programa mais seguro.
- A lista dos 10 Principais Riscos de Segurança em Aplicações Web da OWASP inclui cinco falhas diretamente relacionadas a código de software inseguro.
- **Estas falhas incluem:**
 - Entrada de dados não validada.
 - Cross-site scripting (XSS).
 - Estouro de buffer.
 - Falhas de injeção.
 - Tratamento inadequado de erros.

As Falhas Mais Perigosas (CWE/SANS Top 25)

- A lista **CWE/SANS Top 25 Most Dangerous Software Errors** detalha o consenso sobre práticas que causam a maioria dos ciberataques.
- **As falhas são agrupadas em 3 categorias:**
 - 1. Interação Insegura entre Componentes.
 - 2. Gerenciamento de Recursos Arriscado.
 - 3. Defesas Porosas.

Categoria de Erro de Software: Interação Insegura entre Componentes

- Neutralização Imprópria de Elementos Especiais usados em um Comando SQL (“Injeção de SQL”)
- Neutralização Imprópria de Elementos Especiais usados em um Comando do SO (“Injeção de Comando do SO”)
- Neutralização Imprópria de Entrada Durante a Geração de Página Web (“Cross-site Scripting”)
- Upload Irrestrito de Arquivo com Tipo Perigoso
- Falsificação de Solicitação entre Sites (CSRF)
- Redirecionamento de URL para Site Não Confiável (“Redirecionamento Aberto”)

Categoria de Erro de Software: Gerenciamento de Recursos Arriscado

- Cópia de Buffer sem Verificar o Tamanho da Entrada (“Estouro de Buffer Clássico”)
- Limitação Imprópria de um Nome de Caminho para um Diretório Restrito (“Path Traversal”)
- Download de Código Sem Verificação de Integridade
- Inclusão de Funcionalidade de Esfera de Controle Não Confiável
- Uso de Função Potencialmente Perigosa
- Cálculo Incorreto do Tamanho do Buffer
- String de Formatação Não Controlada
- Estouro de Inteiro ou *Wraparound*